

08_SECURITY.md

TASK 08

SECURITY IMPLEMENTATION & HARDENING

Status

Mandatory

Owner

Security Architect

Supporting Guides

Project Director

Backend Lead

Frontend Lead

Database Architect

QA & Security Lead

Principal Engineer

Estimated Time

2 to 3 Days

Dependencies

00_PROJECT_CONTEXT.md

00_ENGINEERING_RULES.md

00_PROJECT_MEMORY.md

03_SECURITY_ARCHITECT.md

06_BACKEND.md

07_FRONTEND.md

Mission

Perform a complete security review and hardening of the Secure Dance Academy Management System.

Verify every security control.

Implement missing protections.

Remove security weaknesses.

Produce evidence demonstrating compliance with secure software engineering principles.

Security is not complete until it has been verified.

Objectives

Complete application hardening.

Protect every endpoint.

Protect every user.

Protect every session.

Protect every database operation.

Reduce attack surface.

Prepare the application for penetration testing.

Security Standards

Every implementation must align with

OWASP Top 10

OWASP ASVS

OWASP Cheat Sheets

NIST Secure Software Development Framework

CWE Top 25

Secure SDLC

Document every control implemented.

Authentication Review

Verify

Registration

Login

Logout

Forgot Password

Password Reset

Email Verification

Session Refresh

Session Expiration

Password Change

Remember Me

Session Revocation

Protect every authentication workflow.

Authorization Review

Review every endpoint.

Verify

Authentication

Role

Permission

Ownership

Context

Resource Access

Least Privilege

Parents access only their own children.

Coaches manage only assigned artists.

Artists access only their own records.

Administrators receive controlled privileged access.

Session Security

Verify

Secure Cookies

HTTP Only

SameSite

Session Timeout

Session Rotation

Session Revocation

Concurrent Sessions

Session Expiration

Protection against

Session Hijacking

Session Fixation

Replay Attacks

Password Security

Verify

Minimum Length

Complexity

Hashing

Password Reset

Password Change

Password Reuse Prevention

Password Strength Meter

Never store plaintext passwords.

Input Validation

Review every endpoint.

Validate

Body

Query

Route Parameters

Headers

Files

Reject malformed requests.

Prevent mass assignment.

Prevent over-posting.

Output Protection

Protect against

Stored XSS

Reflected XSS

DOM XSS

Unsafe HTML Rendering

Unsafe Markdown

Unsafe File Downloads

Escape all dynamic content.

API Security

Verify every endpoint.

Authentication

Authorization

Validation

Rate Limiting

Audit Logging

Consistent Errors

Secure Headers

Minimal Data Exposure

No endpoint should expose unnecessary information.

Database Security

Review

Prisma

Parameterized Queries

Foreign Keys

Constraints

Indexes

Transactions

Row Level Security

Least Privilege

Environment Variables

No direct SQL injection paths should exist.

File Upload Security

Verify

Allowed Types

Maximum Size

Filename Validation

MIME Validation

Storage Location

Virus Scan Support

Prevent executable uploads.

Rename uploaded files.

Security Headers

Configure

Content Security Policy

Strict Transport Security

Referrer Policy

Permissions Policy

X Frame Options

X Content Type Options

Cross Origin Policies

Verify every header.

Rate Limiting

Protect

Authentication

Password Reset

Search

Reports

Public APIs

Sensitive Operations

Document thresholds.

Error Handling

Verify

Validation Errors

Authentication Errors

Authorization Errors

Unexpected Errors

Never expose

Stack Traces

SQL Queries

Secrets

Framework Internals

Audit Logging

Verify

Login

Logout

Failed Login

Role Changes

Attendance Changes

Medical Updates

Administrative Actions

Security Events

Audit logs must remain immutable.

Secrets Management

Review

Environment Variables

API Keys

Database Credentials

Supabase Keys

Application Secrets

Never hardcode secrets.

Never expose secrets in logs.

Privacy Controls

Verify

Data Minimisation

Consent

Retention

Deletion

Medical Record Protection

Child Information Protection

Access Restrictions

Support GDPR and Singapore PDPA.

Dependency Security

Review every package.

Identify

Outdated Dependencies

Known Vulnerabilities

Unused Packages

High Risk Libraries

Update where appropriate.

Threat Model Validation

Review

Spoofing

Tampering

Repudiation

Information Disclosure

Denial of Service

Elevation of Privilege

Verify mitigations remain effective.

Security Checklist

Confirm

Authentication Protected

Authorization Protected

Validation Complete

Sessions Protected

Cookies Protected

Secrets Protected

Database Protected

API Protected

Frontend Protected

Infrastructure Protected

Documentation

Produce

Security Architecture

Security Checklist

Threat Model

OWASP Mapping

NIST Mapping

Mitigation Matrix

Security Review Report

Residual Risk Report

Security Decision Record

Compliance Summary

Acceptance Criteria

Every authentication flow works securely.

Every authorization rule is enforced.

No critical OWASP Top 10 issues remain.

Sessions are protected.

Audit logging works.

Rate limiting works.

Security headers are configured.

Secrets remain protected.

Residual risks are documented.

Update Project Memory

Mark

Security Implementation

Completed

Record

Security Controls

Threat Model Version

Security Review Date

Residual Risks

Outstanding Issues

Next Task

Testing & Verification

Security Review Checklist

Verify

Authentication passes.

Authorization passes.

Input validation passes.

Output encoding passes.

Sessions are secure.

Rate limiting works.

Audit logging works.

Security headers exist.

Dependencies are secure.

Residual risks are acceptable.

Documentation is complete.

Definition of Done

The application has undergone a complete security hardening process.

All approved security controls have been implemented and verified.

Critical and high-risk vulnerabilities have been resolved.

Security documentation is complete.

The application is approved for comprehensive testing, penetration testing and final verification before deployment.